PERC20 Action Circuit Security Audit Report (Round 5)

Audit target: `circuits/action.circom` as the `main` entry of the Groth16 action circuit (the full C-1…C-8 subcircuit set), re-audited on the **current source** with all prior-round fixes applied (including this cycle's H-01 and D-1 resolutions).
Method: Manual, file-by-file, constraint-by-constraint cryptographic review — constraint completeness, range/canonicity, subgroup/curve, domain separation, malleability, public-input binding, and cross-component signal consistency.

---

1. Overview

This fifth round independently re-reviews the entire `action.circom` family from scratch, on the source as it stands after rounds 0–4 and the most recent cycle of fixes. Its three goals mirror the prior rounds:

1. **Regression verification** — confirm, constraint-by-constraint, that every prior fix (round-0 A–F; round-1 A/B/C; round-2 D-1/D-2; round-4 **H-01**) is present in the current code, correctly implemented, and not weakened by later changes (notably the EIP-1167 clone-factory refactor and the multi-output-mint prover work, neither of which touches the circuit);
2. **In-depth re-review** — fully re-check the core security properties (value conservation, 64-bit ranges, scalar canonicalization, subgroup/curve/`x≠0`, nullifier, soft Merkle, frozen-IMT non-membership, public-input binding, domain separation, cross-component signal consistency);
3. **New findings** — look for issues the prior rounds did not cover, with particular attention to the two structural changes since round-4: the C-8 rebinding to the **consumed** note commitment (H-01) and the removal of the C-6 `CommitIvkScaffold` (D-1).

Overall conclusion: the circuit remains **robust** across all core ZK security constraints. This round found **no high/critical defect** that could enable counterfeiting, double-spend, or freeze-bypass. All prior fixes are confirmed correctly in place (see the per-item regression in §8). The two most significant changes since round-4 — **H-01** (compliance non-membership now binds the consumed note `cm_old`, not the prover-chosen output `cmx`) and **D-1** (the vestigial `CommitIvkScaffold` removed) — are both verified **correct and complete**. This round adds **1 new Issue (Low — auditability, not exploitable)** and provides status updates for the carried-over Suggestions.

> **Current R1CS** (recompiled this round, `circom action.circom --r1cs`): non-linear **79,084**, linear **52,703**, wires **131,812**, template instances **66**, public inputs **1**, private inputs **2,361**. The drop from round-2's 80,736/72 is exactly the D-1 `CommitIvkScaffold` removal (≈1,652 non-linear constraints, ≈73 private inputs). The H-01 rebinding (`c8.cmx <== c1.cm_old_x`) is a wiring change and does not alter the constraint *count*.

Findings Summary

ID	Title	Severity	Status
Issue G-1	Orphaned compile-time constants (`TWO_POW*`, `COMMIT_IVK_T_P`, `RHO_T_P`) in `constants.circom` after scaffold removals	Low / Informational	**Resolved** (new; fixed this round)
Issue H-01	Compliance non-membership bound to the output `cmx` instead of the consumed `cm_old` (round-4)	High	**Resolved** (verified this round)
Issue D-1	C-6 `CommitIvkScaffold` vestigial Sinsemilla scaffold (round-2)	Low	**Resolved** (verified this round)
Issue D-2	`note_commit/scaffold.circom` + `Decompose*` dead code (round-2)	Low	**Resolved** (verified this round)
Suggestion 2	`CommitIvk` binds only `ak_x`; `ak_y` is free (round-1)	Informational	Open
Suggestion 3	`v_old=0` soft-Merkle dummy-spend nullifier semantics should be documented (round-1)	Informational	Open
Suggestion 4	Single public input must be cross-tested field-by-field vs on-chain `ActionPubHash.sol` (round-1)	Informational	Open
Suggestion 5	Poseidon permutation is auto-generated; pin generator + vector tests in CI (round-1)	Informational	Open
Suggestion 6	A formal MPC ceremony is required before mainnet (round-1)	Informational	Open
Suggestion 7	`EscalarMulFix` 254-bit scalar exceeds the 251-bit subgroup order; document the reduction (round-1)	Informational	Open
Suggestion 9	Fixed-base NUMS generators lack a recorded offline "in prime-order subgroup" verification (round-2)	Informational	Open
Suggestion 13	Populated-blacklist non-membership witness generation is a separate (off-circuit) trust point (new)	Informational	Open

---

2. Scope

Every subcircuit reachable from `action.circom` under `circuits/` (circomlib under `node_modules` is treated as a trusted third-party library):

- `action.circom` (the `main` entry, `public [pub_hash]`), `constants.circom`
- `poseidon_bn254.circom` (`Hash3` / `MerkleCompress` / `PoseidonNoteInner4` / `PoseidonCmxInner4` / `CommitIvkHash` / `PubHashAction`), `poseidon_permute_bn254.circom`
- `note_commit/commit_old.circom` (C-1), `note_commit/commit_new.circom` (C-7), `note_commit/decompose.circom`
- `merkle32.circom` (C-2), `value_commit.circom` (C-3), `nullifier.circom` (C-4), `spend_auth.circom` (C-5)
- `commit_ivk.circom` (C-6)
- `frozen_cmx_nonmember.circom` (C-8) + `less_than_field.circom`
- `babyjubjub/{add,on_curve,subgroup_check,mul_fix,mul_var}.circom`

> Note vs prior rounds: `note_commit/scaffold.circom` and `commit_ivk_scaffold.circom` are **gone** (deleted in round-2 D-2 and this cycle's D-1, respectively), and `tests/circuits/commit_ivk_test.circom` was removed alongside D-1. The scope shrank accordingly.

Out of scope: on-chain Solidity verification/accounting (`OrchardVerifier.sol` / `PERC20.sol` / `PERC20Factory.sol` / `ActionPubHash.sol` / `BindingSignature` / `SpendAuthSignature`), the Groth16 trusted-setup ceremony, the Rust witness generator, and circomlib internals. Round-4's cross-layer Issue E-1 and Suggestions 10–12 are contract-side and not re-litigated here. Cross-layer consistency conclusions (Suggestions 4/5/9) are stated from the circuit side; the on-chain/offline side must be verified separately.

---

3. Methodology

Per-subcircuit checklist (unchanged from round-2/4, with item 8 cross-component consistency emphasized given the H-01 rebinding):

1. **Constraint completeness** — is every free witness constrained? Any "assign-only, no constraint" under-constraint, or scaffolds that "look like constraints" but are vestigial/dangling?
2. **Bit-decomposition safety** — are the bit arrays driving `EscalarMul` boolean-constrained (`b·(1-b)=0`)? Is the recomposition `AliasCheck`-ed (< p) to rule out mod-p aliasing?
3. **Curve-point validity** — are externally-witnessed points on-curve **and** prime-order-subgroup checked (including exclusion of the identity `O`)?
4. **Range checks** — are values entering commitments/comparisons locally constrained to the intended bit-width?
5. **Domain separation** — are the Poseidon domain tags (Merkle levels, CM/CMX, NF, IVK, frozen leaf/node, action type) mutually disjoint?
6. **Malleability / public-input binding** — are all 8 on-chain-visible fields uniquely bound into `pub_hash`?
7. **Comparison against the Orchard / Halo2 reference** — constraints weakened/omitted in porting, or irrelevant constraints left behind.
8. **Cross-component signal consistency** — is each logical quantity (`v_old` / `rho_old` / `psi_old` / `cm_old` / `nf_old` / `cmx`) driven by the **same top-level signal** across subcircuits, ruling out "commit value A in one place, use value B elsewhere" — the exact failure class that H-01 was?

---

4. System & Security Model (brief)

The top-level circuit proves one "spend an old note, create a new note" action. The old note is proven to exist and be unspent via **C-1** (Poseidon→Pedersen commitment `cm_old = [inner]·G_NOTE + [rcm_old]·H_NOTE`, leaf = `cm_old.x`) + **C-2** (32-level Merkle inclusion, `anchor` a historical root, softened when `v_old=0`) + **C-4** (nullifier `nf_old = ([Hash3(NF_D0,nk,ρ)+ψ]·G_NULLIFIER + cm_old).x`). The new note is produced via **C-7** yielding `cmx`, with `ρ_new := nf_old` (prevents ρ reuse). Value conservation is carried by **C-3**'s homomorphic value commitment `cv_net = ±[magnitude]·G_VALUE + [rcv]·G_RANDOM`, with the final balance check (`Σ cv = valueBalance·G_VALUE + …`) performed by the **on-chain binding signature**. Spend authorization is produced by **C-5** (`rk = ak + [α]·G_SPEND_AUTH`, Schnorr verified on-chain), with `ak` bound to the note key tree via **C-6** (`ivk = CommitIvk(ak_x,nk,rivk)`, `pk_d_old = [ivk]·g_d_old`). Compliance is carried by **C-8**'s frozen-set Indexed-Merkle-Tree non-membership proof — **as of round-4 (H-01), bound to the consumed note `cm_old.x`**. The circuit exposes a single public input `pub_hash = PubHashAction(anchor, cv_net_x, cv_net_y, nf_old, rk_x, rk_y, cmx, rt_frozen)`.

---

5. Severity Classification

Following the Least Authority two-tier system:

- **Issue** — a problem directly related to security/correctness, labeled internally Critical / High / Medium / Low by impact and exploitability.
- **Suggestion** — an improvement to robustness, maintainability, or auditability that is not a direct vulnerability.

---

6. Issues

Issue G-1 (new) — Orphaned compile-time constants left over from the removed Sinsemilla scaffolds

Severity: Low / Informational (auditability; no R1CS or runtime impact)

Synopsis
After rounds 1/2 removed `NoteCommitScaffold` + `note_commit/scaffold.circom` (Issue C / D-2) and this cycle removed `CommitIvkScaffold` (D-1), `constants.circom` still defines a block of compile-time constant functions that **only those Sinsemilla scaffolds ever used**: `TWO_POW1 … TWO_POW254` (the `2^k` ladder for Sinsemilla bit-chunk arithmetic), `COMMIT_IVK_T_P`, and `RHO_T_P` (`constants.circom:62-91`, under the comment "Powers of two (BN254 migration note-commit scaffold)").

A whole-tree grep confirms these symbols are referenced in **0** production circom files (and 0 outside `constants.circom`/tests): `TWO_POW1`, `TWO_POW130`, `TWO_POW254`, `COMMIT_IVK_T_P`, `RHO_T_P` all resolve to zero live call-sites. They are dead.

This is **exactly homologous to round-2 Issue D-2** (the dead `Decompose*` templates), one layer down: D-2 deleted the dead *templates*, but the *constants* those templates consumed survived.

Impact

- Pure auditability: the names (`COMMIT_IVK_T_P`, `RHO_T_P`, the `TWO_POW*` ladder) evoke active Sinsemilla

canonicity machinery and invite a reviewer to assume such gates still exist — the same misleading surface D-2 flagged. They are not load-bearing.
- No constraint-system impact: these are compile-time `function`s; an un-called function emits no R1CS. Removing them does **not** change the R1CS and needs **no** matched-set regeneration.

Preconditions
None (always holds).

Remediation
Delete the `TWO_POW*` ladder, `COMMIT_IVK_T_P`, and `RHO_T_P` from `constants.circom` (keep the live constants: domain tags, NUMS generators, `SUBGROUP_ORDER*`, `FR_BITS` / `V_NET_BITS`, `MERKLE_DEPTH`, `FROZEN_IMT_*`, `POSEIDON_CAP*`, `DOMAIN_ACTION_V1`). Recompile afterward to confirm the R1CS is byte-identical (evidence the removed constants were dead). Before deleting, grep `tests/circuits/*.circom` — if a surviving test circuit still references any `TWO_POW*`, either migrate it or remove the stale test together with the constant.

Status: Resolved (fixed this round). The 29-line orphaned block (`TWO_POW1…TWO_POW254`, `COMMIT_IVK_T_P`, `RHO_T_P`) and its header comment were deleted from `constants.circom`; all live constants retained, file now ends at `G_NULLIFIER_Y`. Whole-tree grep confirmed **0** references in any production circom, `tests/circuits/*.circom`, or JS/TS test. Compiling `action.circom` before vs. after the deletion yields a **byte-identical** `action.r1cs` (sha256 `01f24dd4…0227`; 79,084 non-linear / 52,703 linear / 131,812 wires / 251,204 labels unchanged) — proof the constants were dead. No `action_final.zkey` / `Groth16PairingVerifier.sol` / `e2e/fixtures` regeneration required.

Issue H-01 (round-4) — Compliance non-membership bound to the consumed note: Resolved, verified this round

Severity: High (compliance/freeze control). Not a theft/inflation vector (value conservation is independent).

What was wrong (round-4): C-8 fed the non-membership gadget the **output** commitment `cmx_pub` (`c7.cmx`), whose randomness the prover controls — making the freeze a cryptographic no-op — and never checked the **consumed** note `cm_old`, so a frozen note could be freely spent.

Verification this round (constraint-by-constraint):

- `action.circom:201` now wires `c8.cmx <== c1.cm_old_x` — the consumed note commitment, identical to the signal used for Merkle inclusion (`c2.leaf <== c1.cm_old_x`, line 130) and the nullifier (`c4.cm_old_x <== c1.cm_old_x`, line 142). So the note proven *in the tree*, *nullified*, and *checked non-frozen* are provably the **same** note — the cross-component consistency that was broken is now closed.
- `frozen_cmx_nonmember.circom` is unchanged and correct: low-leaf `Hash3(240, val, next)`, Merkle inclusion to `rt_frozen`, strict bracketing `low_val < cm_old.x ∧ (next=0 ∨ cm_old.x < next)` via the full-field-safe `LessThanField`. A frozen `cm_old.x` equals some leaf's `val`, so no in-tree leaf can strictly bracket it → the proof is unsatisfiable.
- A fail-closed **negative test** was added (`circuits/tests/witness_frozen_nonmember.test.js`): for a populated blacklist that *contains* `cm_old.x`, witness generation fails (`Assert Failed`); for an empty or non-containing blacklist it succeeds. Before the fix the frozen case would have passed.

Status: Resolved.

Issue D-1 (round-2) — C-6 `CommitIvkScaffold` removed: Resolved, verified this round

`action.circom` no longer instantiates `CommitIvkScaffold`; `commit_ivk_scaffold.circom` and its only consumer test were deleted. C-6 (`commit_ivk.circom`) now derives `ivk = CommitIvkHash(ak_x,nk,rivk)` (Poseidon) and pins it with `Recompose254(ivk_bits) === ivk` (per-bit boolean + `AliasCheck < p`), then `pk = BJJMulVar254(ivk_bits, g_d); pk.out === pk_d`. The sole source of ivk canonicity is `Recompose254` — exactly as round-2 predicted — and removing the scaffold provably strengthens nothing and weakens nothing. R1CS dropped 80,736 → **79,084** non-linear, confirming the scaffold was the only thing removed.

Status: Resolved. (Issue D-2 likewise remains Resolved; the residual constants it left behind are now Issue G-1.)

---

7. Suggestions

Suggestion 13 (new) — Populated-blacklist non-membership witness generation is an off-circuit trust point

With H-01, the security value of C-8 depends on the prover being **able** to produce a valid bracketing low-leaf for any non-frozen `cm_old.x`, and being **unable** to for a frozen one. The circuit enforces the latter (unsatisfiable bracketing). The former — building the sorted Indexed Merkle Tree, its `rt_frozen` root, and the bracketing witness — lives entirely off-circuit (the Rust `poseidon_merkle_bn254::frozen_*` helpers added this cycle). This is the same "trust the admin/relayer to maintain a well-formed sorted IMT" assumption the C-8 comment already states, now extended to a non-empty blacklist. **Recommendation**: document that (a) a malformed or stale `rt_frozen` is a liveness (not soundness) risk — a wrong root just makes honest proofs fail, it cannot let a frozen note through; and (b) add a CI test that exercises a **non-empty** blacklist end-to-end (the new `test:witness:frozen` does this for the circuit; extend it to a multi-entry tree against the contract's `cmxFrozenRoot`).

Suggestions 2–7, 9 (carryovers — status: still Open)

Re-reviewed this round; conclusions unchanged. One-line status each:

- **Suggestion 2** (`CommitIvk` absorbs only `ak_x`; `(ak_x, ±ak_y)` give the same `ivk/pk_d/note`): **Open**. Not exploitable by a keyless adversary (a valid `rk` Schnorr signature still needs the private key); recommend documenting or canonicalizing the `ak_y` sign.
- **Suggestion 3** (`v_old=0` soft-Merkle dummy spend publishes a real nullifier): **Open**. Confirmed the softening gate `(root-anchor)·(1-IsZero(v_old))===0` is correctly driven by the real `v_old`. *New note (H-01 interaction):* a mint's dummy `cm_old.x` now also passes through C-8 non-membership; for a random dummy the collision probability with a frozen value is negligible, and mint is `onlyIssuer` regardless — no liveness or soundness concern, but worth noting in the dummy-spend documentation.
- **Suggestion 4** (single public input must be byte-for-byte cross-tested against `ActionPubHash.sol`): **Open**. Re-confirmed `PubHashAction` is a `ConstantLength<9>` rate-2 sponge: `[DOMAIN_ACTION_V1, anchor, cv_x, cv_y, nf, rk_x, rk_y, cmx, rt_frozen]` over 5 permutations (capacity `POSEIDON_CAP9`), all 8 fields absorbed. Add the circuit-vs-Solidity vector cross-test to CI (this is also round-4's "matched-set CI" carryover).
- **Suggestion 5** (Poseidon permutation auto-generated, backed only by vector tests): **Open**. Pin the

version/hash of `gen_poseidon_circom.py` + source `PoseidonT3.sol` and enforce the vector tests in CI. *(Note: `gen:poseidon` currently reads `contracts/PoseidonT3.sol`, which is absent in some checkouts — see the build caveat; the committed `poseidon_permute_bn254.circom` is the source of truth.)*

- **Suggestion 6** (dev trusted setup is not an MPC): **Open — must be completed before mainnet.**
- **Suggestion 7** (`EscalarMulFix` 254-bit scalar exceeds the 251-bit `ℓ`; `[s]·G=[s mod ℓ]·G`): **Open**. Safe for commitments (opening values are `Recompose254`-canonical); recommend a comment stating the reduction semantics.
- **Suggestion 9** (fixed-base NUMS generators lack a recorded offline subgroup verification): **Open**. The six generators (`G_VALUE/G_RANDOM/G_NOTE/H_NOTE/G_NULLIFIER/G_SPEND_AUTH`) are compile-time constants the circuit cannot subgroup-check; the completeness of every `BJJAdd` (cm/nf/rk/cv) and the binding/hiding of the value commitment **rely on them being prime-order**. Add a one-time offline assertion (`on-curve ∧ [ℓ]G=O ∧ G≠O`) and pin its result in docs/CI. This ties to round-4 Suggestion 11 (the same assumption is load-bearing on-chain).

---

8. Positive Findings & Regression of Prior-Round Fixes

Confirmed correct, constraint-by-constraint, on the current source:

Regression of prior-round fixes

- **round-0 A (scalar bits not boolean-constrained) → present**: every bit array driving an `EscalarMul` is canonicalized by `Recompose254` (`inner_bits` C-1/C-7, `rcm_*_bits` C-1/C-7, `ivk_bits` C-6, `nf_scalar_bits` C-4, `alpha_bits` C-5, `rcv_bits` C-3) — per-bit `b·(1-b)=0` + `AliasCheck < p` (`decompose.circom:39-54`); the **same** bits drive both the recompose and the multiplier. `magnitude_bits`/`v_*_bits` use `Recompose64` (per-bit boolean; 64 bits inherently canonical).
- **round-0 B (Merkle `path_bits` not boolean) → present**: `merkle32.circom:36` and `frozen_cmx_nonmember.circom:50` both enforce `path_bits·(1-path_bits)=0`.
- **round-0 C (magnitude lacks 64-bit range) → present**: `value_commit.circom:29-33` `Recompose64(magnitude_bits)===magnitude`, and the same `magnitude_bits` drive `BJJMulGValue64`.
- **round-0 D (missing subgroup checks) → present**: `action.circom:84-98` applies `BJJSubgroupCheck` to all 5 externally-witnessed points (`g_d_old / pk_d_old / ak / g_d_new / pk_d_new`).
- **round-0 E (frozen 32-bit SMT key) → resolved by the IMT**: C-8 is an Indexed Merkle Tree with full `(val,next)` leaves sorted by the full `cm_old.x`; depth (`FROZEN_IMT_DEPTH=20`) bounds only capacity, not key space — no suffix collisions.
- **round-0 F (note-inner binds only x) → mitigated**: `PoseidonNoteInner4/PoseidonCmxInner4` absorb `g_d_x/pk_d_x` only, but the tree/nullifier are x-keyed (Orchard-consistent) and the subgroup check pins the prime-order one of the two same-x points. Residual is a benign non-binding of `y`.
- **round-1 A (`v_new` lacks 64-bit range) → present**: `commit_new.circom:32-36` `Recompose64(v_new_bits)===v_new`, symmetric to `v_old` (`commit_old.circom:38-42`).
- **round-1 B (subgroup check accepts `O`) → present**: `subgroup_check.circom:74-76` appends `IsZero(x).out===0` after `[ℓ]P=O`, excluding `O=(0,1)` (the 2-torsion `(0,-1)` is excluded by odd `ℓ`); this also satisfies `EscalarMulAny`'s "base in subgroup and ≠0" precondition for `pk_d=[ivk]·g_d`.
- **round-1 C / round-2 D-2 (note scaffold + dead templates) → present**: `commit_old.circom` keeps only `Recompose64(v_old_bits)`; `scaffold.circom` and the `Decompose*` templates are deleted.

- **round-2 D-1 / round-4 H-01 → present**: see §6.

Properties re-confirmed correct this round

- **Value conservation is tight**: `ValueMagnitudeSign` boolean-constrains `sign` and sets `v=(1-2·sign)·magnitude`; `v_old - v_new === v`. With `v_old, v_new, magnitude ∈ [0,2^64)` there is no field-wrap ambiguity. `val_x = out_x + sign·(Fr - 2·out_x)` correctly computes the twisted-Edwards x-negation when `sign=1` (`Fr ≡ 0 mod Fr`).
- **Nullifier canonicalization + consistency**: `scalar = Hash3(NF_D0,nk,ρ)+ψ` pinned by `Recompose254(nf_scalar_bits)===scalar`; `nf_old = ([scalar]·G_NULLIFIER + cm_old).x` via complete `BabyAdd`. The `ρ/ψ/nk` used by C-4 and the `cm_old` point are the **same** signals C-1 commits.
- **Cross-component signal consistency** (focus this round, given H-01): `cm_old` (C-1 output → C-2 leaf, C-4, **C-8**), `v_old` (C-1 commit / C-2 soft gate / C-3 balance), `ρ_old·ψ_old` (C-1 / C-4), `nf_old_pub` (C-4 = / C-7 `ρ_new` / `ph`), `cmx_pub` (C-7 = / `ph`) are each driven by a single top-level signal and locked with `===`. No decoupling remains.
- **Soft Merkle is correct**: `(root-anchor)·(1-IsZero(v_old))===0` — forces `root==anchor` when `v_old≠0`, relaxes for mint/dummy; driven by the real `v_old`, so a nonzero-value note cannot bypass membership.
- **Frozen IMT non-membership is correct**: domain-separated leaf (`240`) / node (`256+i`) hashes; `root==rt_frozen`; strict bracketing via `LessThanField` (`Num2Bits_strict` canonical bits + 127/127 half-comparison). Under the documented "well-formed sorted IMT" trust, a valid proof is a non-membership proof — now of the **consumed** note.
- **Public-input binding has no malleability**: the 9-element sponge absorbs `DOMAIN_ACTION_V1` + all 8 fields; changing any one changes `pub_hash`.
- **Domain separation has no collisions**: note-tree levels `0-31`, CM/CMX `160-163`, NF `176`, IVK `208-209`, frozen leaf `240`, frozen nodes `256-275` — mutually disjoint. (CM and CMX sharing `160-163` is intentional: the note commitment is the same function for old and new notes.)
- **Scalar multiplication is a trusted circomlib thin wrapper**: `mul_fix.circom` = `EscalarMulFix`, `mul_var.circom` = `EscalarMulAny`, `add.circom` = `BabyAdd`, `on_curve.circom` = `BabyCheck`; all bit inputs are boolean-ized by the caller's `Recompose*`.

---

9. Conclusion

The fifth-round audit found **no high/critical defect** that could directly enable counterfeiting, double-spend, or freeze-bypass. All fixes from rounds 0–4 — the round-0 under-constraints, round-1 A/B/C, round-2 D-1/D-2, and round-4 **H-01** — were confirmed **correctly in place** by constraint-by-constraint regression and were not weakened by the intervening EIP-1167 clone-factory and multi-output-mint work (neither of which touches the circuit). The core properties (value conservation, 64-bit ranges, scalar canonicalization, subgroup+curve+`x≠0`, nullifier, soft Merkle, frozen-IMT non-membership of the **consumed** note, public-input binding, domain separation, cross-component signal consistency) are all **correct**.

The single new finding, **Issue G-1**, is **Low/Informational** and was **resolved this round**: compile-time constants (`TWO_POW*`, `COMMIT_IVK_T_P`, `RHO_T_P`) orphaned by the scaffold removals — pure auditability dead-weight, one layer below round-2's D-2 — were deleted from `constants.circom` with no R1CS change (recompile produced a byte-identical `action.r1cs`, so no matched-set regeneration was needed). New

Suggestion 13 records that populated-blacklist non-membership witness generation is an off-circuit trust point (a liveness, not soundness, concern). Round-1/2's Suggestions 2–7 and 9 remain Open — of which **Suggestion 6 (the formal MPC ceremony) must be completed before mainnet**, and **Suggestions 4/9 (matched-set CI cross-test; recorded generator subgroup verification) are the highest-value pre-mainnet hardening**.

> **Matched-set note**: Issue G-1 deletes un-instantiated compile-time constants and **does not** alter the R1CS — no `action_final.zkey` / `Groth16PairingVerifier.sol` / `e2e/fixtures` regeneration is required (recompile to confirm the constraint count is unchanged as evidence). No other change is recommended this round that would touch the constraint system.
>
> This report is a manual static review of the circuit source; it does not cover the on-chain Solidity verification/accounting, the trusted-setup ceremony, or circomlib internals. Cross-layer conclusions (Suggestions 4/5/9) are stated from the circuit side and must be verified separately on the on-chain/offline side.